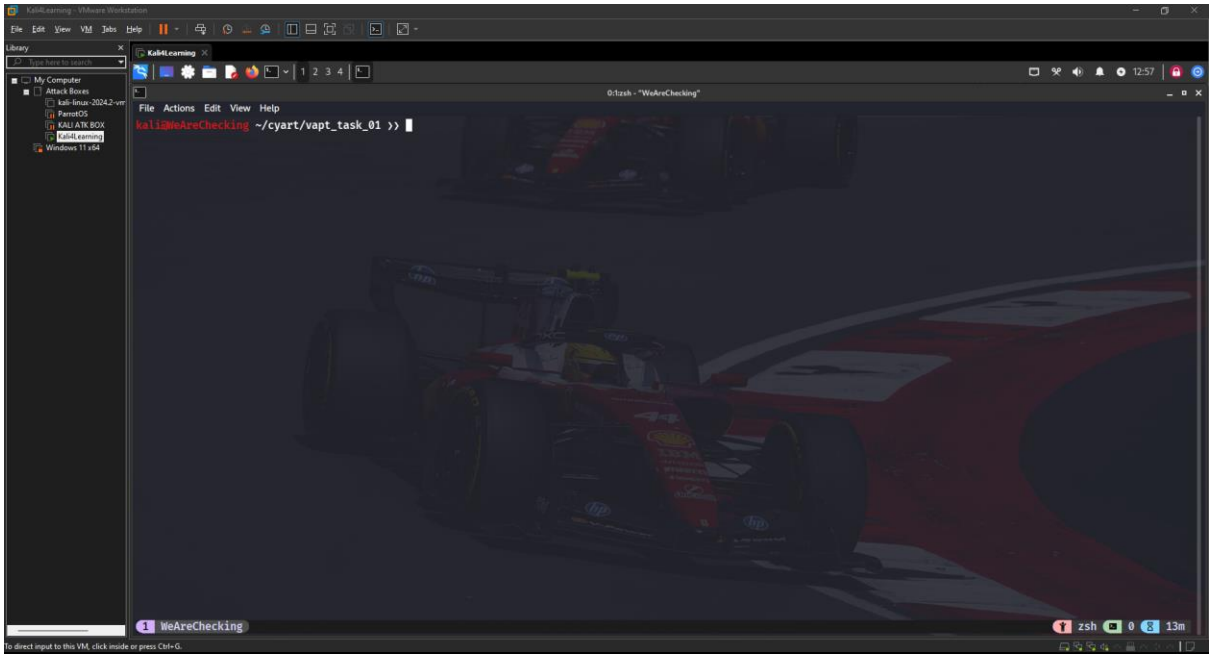
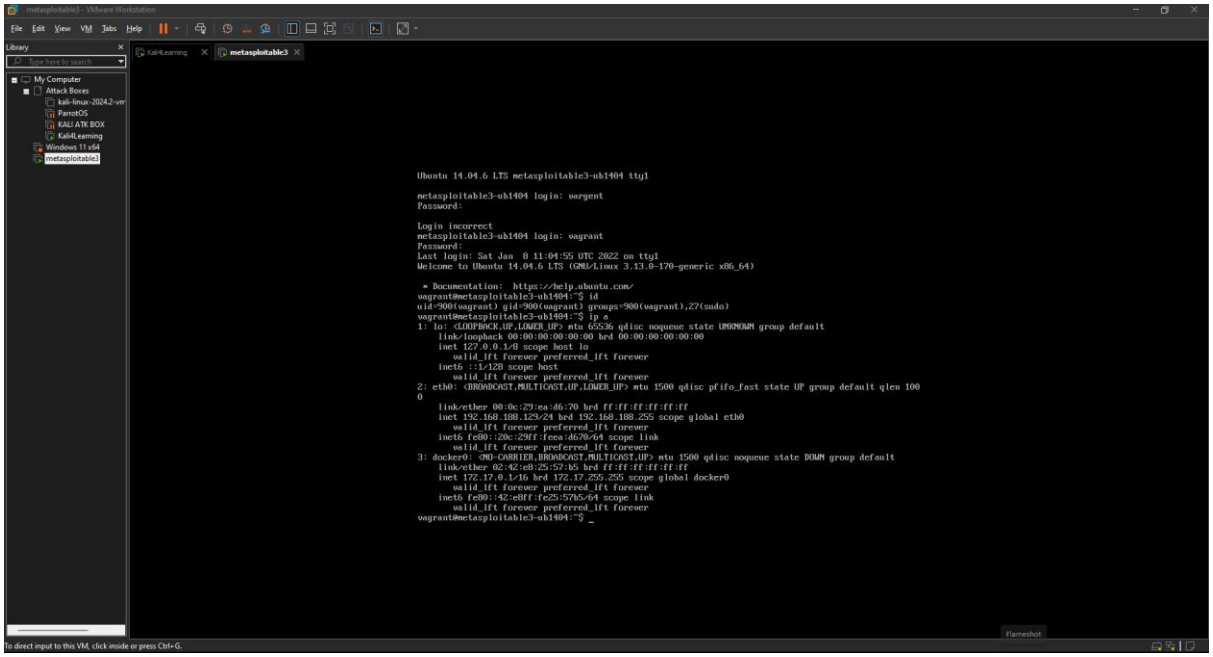
Setting Test Environment

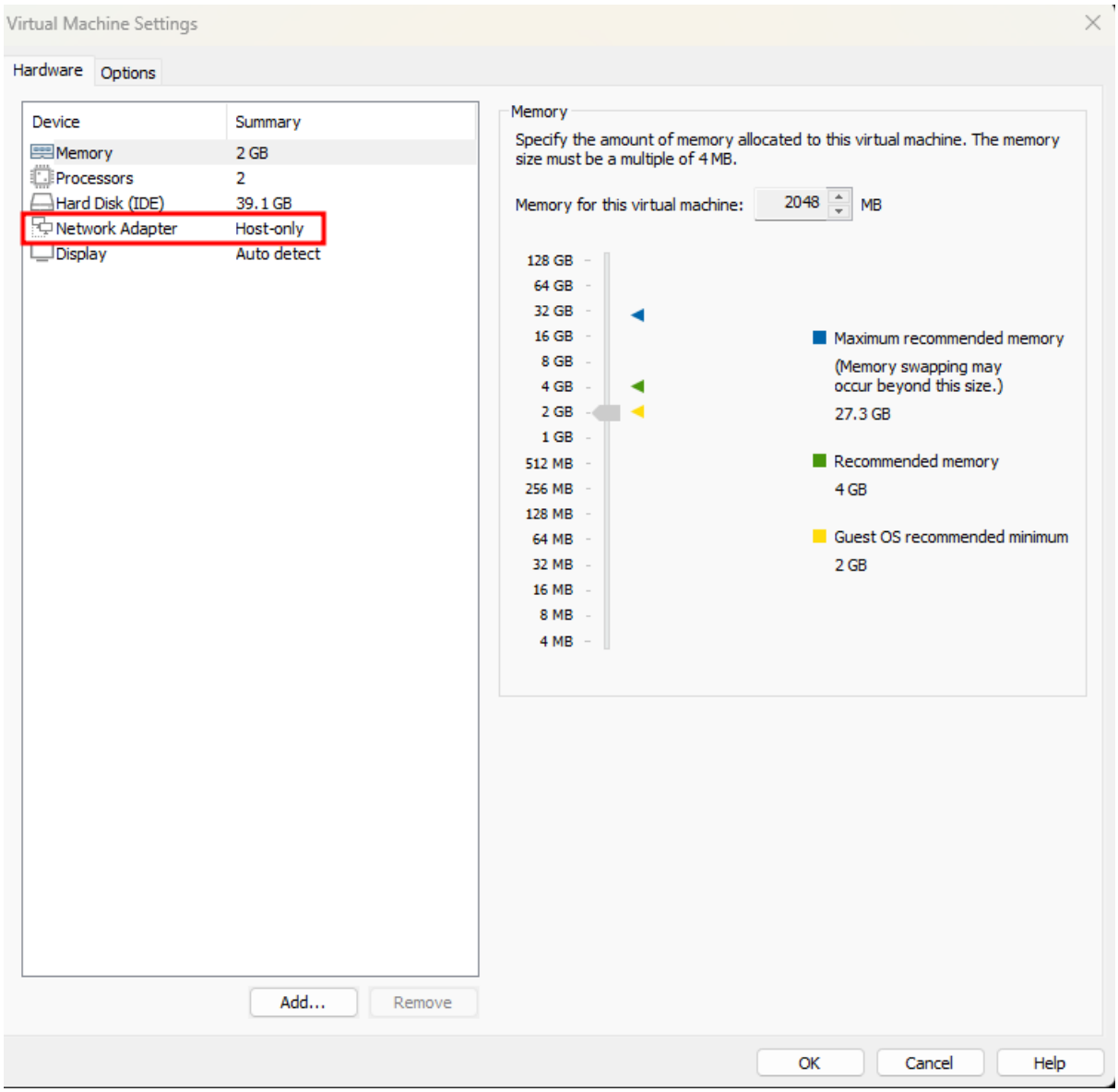
1. Download Kali VM from https://www.kali.org/get-kali/#kali-platforms and install on Vmware.



2. Download prebuilt image of metasploitable 3 from https://sourceforge.net/projects/metasploitable3-ub1404upgraded/files/Metasploitable3-ub1404.ova/download and install it.



3. Set up network settings as host only on both virtual machines.

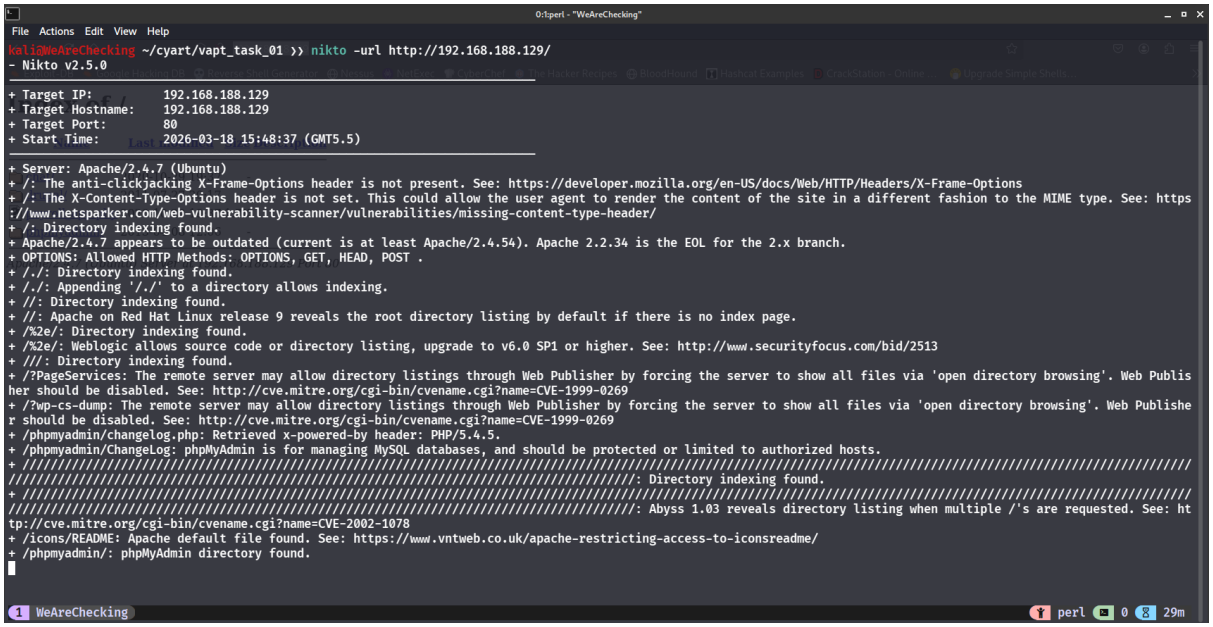


Vulnerability Scanning

Scanning with nikto

Run following command to scan the target with nikto

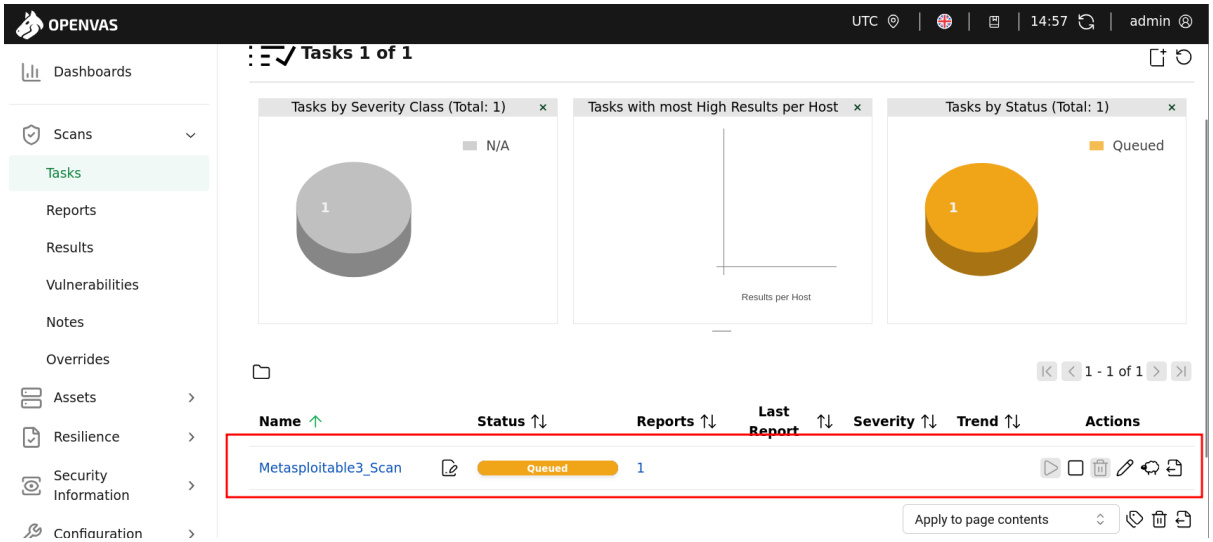
- nikto -url http://<target ip>/

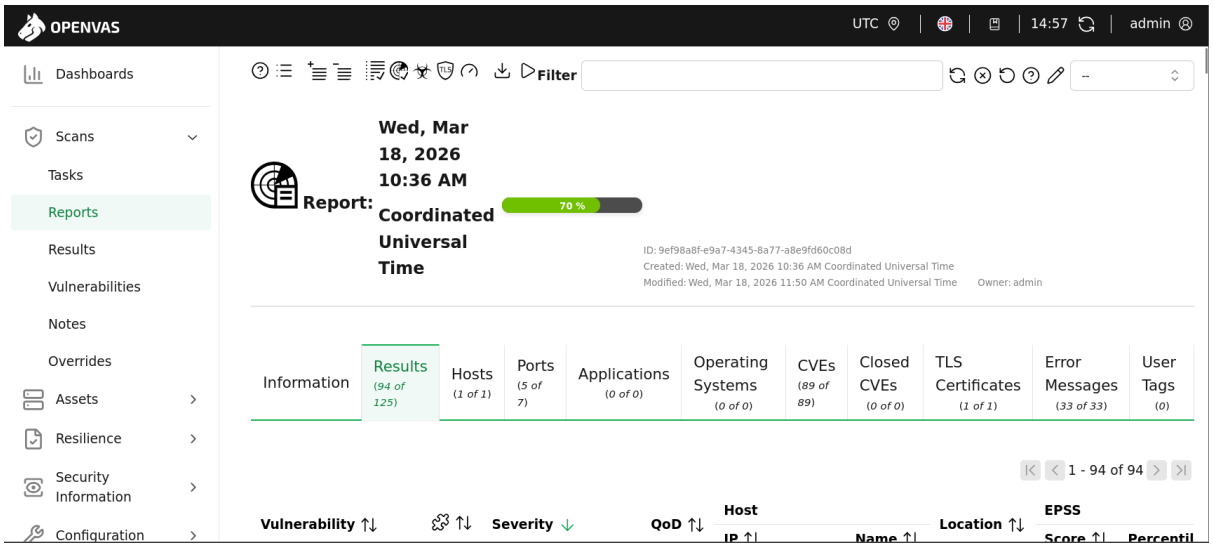


```
0:1:perl - "WeAreChecking"
File  Actions  Edit  View  Help
kali@WeAreChecking ~/cyart/vapt_task_01 ›› nikto -url http://192.168.188.129/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.188.129
+ Target Hostname:    192.168.188.129
+ Target Port:        80
+ Start Time:         2026-03-18 15:48:37 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.7 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https
://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: Directory indexing found.
+ Apache/2.4.7 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /./: Directory indexing found.
+ /./: Appending '/./' to a directory allows indexing.
+ //: Directory indexing found.
+ //: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ /%2e/: Directory indexing found.
+ /%2e/: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: http://www.securityfocus.com/bid/2513
+ ///: Directory indexing found.
+ /?PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publis
her should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publishe
r should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /phpmyadmin/changelog.php: Retrieved x-powered-by header: PHP/5.4.5.
+ /phpmyadmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ ////////////
```

Scanning with OpenVas:

Create a new task with OpenVas and scanning the target.





Document Findings

This table organizes the key vulnerabilities discovered on the host 192.168.188.129.

IP Address	Port	Service	Vulnerability Description	Threat Level (CVSS Score)
192.168.188.129	22/tcp	SSH	**SSH Brute Force Logins With Default Credentials** - Successfully logged in with default credentials vagrant:vagrant.	**Critical (9.8)**
192.168.188.129	631/tcp	IPP (HTTPS)	**Vulnerable Cipher Suites (SWEET32)** - Accepts TLS_RSA_WITH_3DES_EDE_CBC_SHA which is vulnerable to the SWEET32 attack.	**High (7.5)**
192.168.188.129	80/tcp	HTTP	**HTTP Dangerous Methods Enabled** - Supports PUT and DELETE methods, allowing file upload and deletion.	**High (7.5)**
192.168.188.129	22/tcp	SSH	**Weak Host Key Algorithms** - Supports weak host key algorithm ssh-dss (DSA).	Medium (5.3)
192.168.188.129	22/tcp	SSH	**Weak Key Exchange (KEX) Algorithms** - Supports weak KEX algorithms like diffie-hellman-group1-sha1 (1024-bit prime).	Medium (5.3)
192.168.188.129	22/tcp	SSH	**Weak Encryption Algorithms** - Supports weak ciphers including CBC mode ciphers (aes128-cbc) and Arcfour (arcfour).	Medium (4.3)
192.168.188.129	631/tcp	IPP (HTTPS)	**Deprecated TLSv1.0 and TLSv1.1 Protocols** - Supports outdated TLS protocols with known flaws (BEAST, FREAK).	Medium (4.3)
192.168.188.129	80/tcp	HTTP	**Outdated jQuery Library (XSS)** - jQuery versions 1.6.2 found (/phpmyadmin/) vulnerable to multiple XSS flaws (CVE-2012-6708, CVE-2011-4969).	Medium (6.1 / 4.3)
192.168.188.129	80/tcp	HTTP	**Sensitive File Disclosure** - web.config file is accessible (/drupal/web.config), potentially exposing application structure.	Medium (5.0)
192.168.188.129	80/tcp	HTTP	**Unprotected Web App Installer** - phpMyAdmin setup page (/phpmyadmin/setup/) is publicly accessible.	Medium (5.0)

192.168.188.129	80/tcp	HTTP	**Cleartext Transmission of Sensitive Information** - Login forms (e.g., /drupal/, /payroll_app.php) transmit passwords over unencrypted HTTP.	Medium (4.8)
192.168.188.129	general/tcp	TCP/IP	**TCP Timestamps Information Disclosure** - Implements RFC1323 timestamps, allowing system uptime calculation.	Low (2.6)
192.168.188.129	22/tcp	SSH	**Weak MAC Algorithms** - Supports weak MAC algorithms including MD5-based (hmac-md5) and 96-bit based algorithms.	Low (2.6)
192.168.188.129	general/icmp	ICMP	**ICMP Timestamp Reply Information Disclosure** - Responds to ICMP timestamp requests, which can help exploit weak time-based random number generators.	Low (2.1)

Risk Assessment

3x3 Risk Matrix: All Vulnerabilities (192.168.188.129)

	Impact: Low	**Impact: Medium**	**Impact: High**
Likelihood: High	• TCP Timestamps Info Disclosure • ICMP Timestamp Reply		• **Default SSH Credentials** (22/tcp) • **Cleartext Login Forms** (80/tcp) • **HTTP Dangerous Methods** (80/tcp)
Likelihood: Medium	• Weak MAC Algorithms (SSH)	• Outdated jQuery (XSS) - Multiple instances • Weak Encryption Algorithms (SSH) • Weak Key Exchange Algorithms (SSH) • Weak Host Key Algorithms (SSH)	• **Unprotected phpMyAdmin Setup** (80/tcp) • **Sensitive File Disclosure** (80/tcp)
Likelihood: Low		• Deprecated TLSv1.0/1.1 (631/tcp) • Vulnerable Cipher Suites (SWEET32) (631/tcp)	

Vulnerability Placement Justification

Vulnerability	CVSS	Likelihood	Impact	Justification
Default SSH Credentials	9.8 (Critical)	**High**	**High**	vagrant:vagrant is a well-known default. Automated scanners and attackers will find this instantly. Leads to full system compromise.
Cleartext Login Forms	4.8 (Medium)	**High**	**High**	On a local network, sniffing passwords from HTTP traffic is trivial. Compromised credentials can lead to application or data access.
HTTP Dangerous Methods (PUT/DELETE)	7.5 (High)	**High**	**High**	Easily exploitable. An attacker can upload a webshell (PUT) and then delete files (DELETE), leading to code execution and defacement.
Unprotected phpMyAdmin Setup	5.0 (Medium)	**Medium**	**High**	Requires the attacker to know or guess the /setup/ path. If accessed, the attacker can reconfigure phpMyAdmin, potentially gaining database access, which is a high-impact breach.
Sensitive File Disclosure (web.config)	5.0 (Medium)	**Medium**	**High**	The file is accessible, but the attacker must know to request it. The file may reveal database connection strings or application structure, leading to further compromise.
Outdated jQuery (XSS)	6.1 / 4.3	**Medium**	**Medium**	Exploitation requires tricking a user or chaining with another vulnerability. Success can lead to session hijacking or defacement.
Weak SSH Algorithms (E ncryption/KEX/ Host Key)	4.3 - 5.3	**Medium**	**Medium**	Exploiting weak algorithms like CBC mode or 1024-bit DH requires a Man-in-the-Middle (MitM) position and significant computational resources, but successful decryption is possible.
Deprecated TLS Protocols & Weak Ciphers	4.3 - 7.5	**Low**	**Medium**	Exploiting SWEET32 or BEAST requires a MitM position and specific conditions. The impact is eavesdropping on encrypted traffic, potentially revealing sensitive data.
Weak MAC Algorithms (SSH)	2.6	**Medium**	**Low**	Algorithms like hmac-md5 have theoretical collisions. Exploitation is extremely complex and offers minimal direct impact compared to other flaws.
ICMP/TCP Timestamps	2.1 - 2.6	**High**	**Low**	These are information disclosure issues. They are very easy to obtain (High likelihood) but the information (system uptime) is of low value to an attacker and cannot directly compromise the system.

Vulnerability Assessment Report

1. Executive Summary

This report presents the findings of a comprehensive **Vulnerability Assessment and Penetration Testing (VAPT)** conducted on a controlled lab environment consisting of a vulnerable virtual machine (Metasploitable) and an attacker machine (Kali Linux). The assessment was performed using industry-standard open-source tools to simulate real-world attack scenarios and identify security weaknesses in network services and web applications. The primary objective of this assessment was to evaluate the security posture of the target system by identifying vulnerabilities, analyzing their potential impact, and recommending appropriate remediation measures. The testing followed a structured methodology aligned with widely accepted practices, including reconnaissance, vulnerability scanning, analysis, and reporting.

During the assessment, multiple vulnerabilities were identified across different layers of the system. These include insecure configurations in network services, usage of outdated and deprecated cryptographic protocols, and exposure of sensitive information through unencrypted communication channels. Notably, the presence of weak encryption algorithms in SSH and TLS services significantly increases the risk of data compromise, while the use of cleartext HTTP communication exposes sensitive credentials to interception attacks such as Man-in-the-Middle (MitM).

In addition, several low-severity vulnerabilities related to information disclosure were observed, such as TCP and ICMP timestamp responses, which could aid attackers during the reconnaissance phase. While these issues may not directly lead to system compromise, they contribute to the overall attack surface and should not be overlooked.

The vulnerabilities identified were analyzed using the Common Vulnerability Scoring System (CVSS) to determine their severity and prioritize remediation efforts. Based on this assessment, the overall risk level of the system is classified as **Medium to High**, primarily due to weaknesses in encryption mechanisms and insecure communication practices.
If left unaddressed, these vulnerabilities could allow attackers to intercept sensitive data, weaken authentication mechanisms, and potentially gain unauthorized access to system resources. Therefore, it is strongly recommended to implement the suggested remediation measures, including upgrading cryptographic protocols, enforcing secure communication channels, and hardening system configurations.

This report provides detailed technical insights into the identified vulnerabilities along with practical recommendations to mitigate risks and improve the overall security posture of the system.

2. Methodology

The assessment followed a structured VAPT approach:

2.1 Planning

- Scope: Local VM network (Kali Linux ↔ Metasploitable)
- Tools used:
  - Nmap
  - OpenVAS
  - Nikto

2.2 Discovery

- Network scanning using Nmap to identify open ports and services
- Vulnerability scanning using OpenVAS
- Web server analysis using Nikto

2.3 Analysis

- Identified vulnerabilities mapped with CVSS scoring
- Risk categorized into High, Medium, and Low

3. Technical Details and Remediation

3.1. Critical Findings

Service (Port)	Threat Level	CVSS Score	Vulnerability Name
22/tcp	**Critical**	**9.8**	SSH Brute Force Logins With Default Credentials

Screenshot/Evidence:

2.1.1 Critical 22/tcp

Critical (CVSS: 9.8)

NVT: SSH Brute Force Logins With Default Credentials Reporting

Vulnerability Description:

The SSH server on the target allows login using well-known default credentials. The scanner successfully authenticated using the username "vagrant" and password "vagrant".

Impact:

A remote attacker can gain full, unauthorized shell access to the system. This is the highest level of compromise, allowing the attacker to:

- Execute arbitrary commands.
- Install persistent backdoors, malware, or ransomware.
- Steal, modify, or delete all data on the host.

- Use the compromised host as a pivot point to attack other systems on the internal network.

Remediation Steps:

1. **Immediate Action:** Change the password for the 'vagrant' user immediately.
    - sudo passwd vagrant
2. **Permanent Fix:** Disable default and unused user accounts. Implement a strong password policy. Enforce SSH key-based authentication and disable password-based authentication if possible.
    - Edit the SSH configuration file: sudo nano /etc/ssh/sshd_config
    - Set PasswordAuthentication no
    - Set PermitEmptyPasswords no
    - Restart the SSH service: sudo systemctl restart sshd

3.2. High Findings

Service (Port)	Threat Level	CVSS Score	Vulnerability Name
80/tcp	**High**	**7.5**	Test HTTP dangerous methods
631/tcp	**High**	**7.5**	SSL/TLS: Report Vulnerable Cipher Suites for HTTPS

A. Test HTTP dangerous methods (80/tcp)

Screenshot/Evidence:

2.1.3 High 80/tcp

High (CVSS: 7.5)

NVT: Test HTTP dangerous methods

Vulnerability Description:
The web server is misconfigured to allow dangerous HTTP methods like PUT (upload) and DELETE.

Impact:

- **PUT Method:** An attacker can upload malicious files, such as a PHP web shell, to the server. By accessing the uploaded file, they can execute system commands, effectively compromising the web server.
- **DELETE Method:** An attacker can delete files and directories on the web server, potentially leading to data loss or denial of service.

Remediation Steps:

1. **Apache:** Disable these methods in the Apache configuration (e.g., httpd.conf or .htaccess) using the <LimitExcept> directive.
2. **Nginx:** Reject PUT and DELETE methods in the server configuration block.
3. **IIS:** Use Request Filtering to deny specific HTTP verbs.

B. SSL/TLS: Report Vulnerable Cipher Suites for HTTPS (631/tcp)

Screenshot/Evidence:

2.1.2 High 631/tcp

High (CVSS: 7.5)

NVT: SSL/TLS: Report Vulnerable Cipher Suites for HTTPS

Vulnerability Description:
The service on port 631 accepts the TLS_RSA_WITH_3DES_EDE_CBC_SHA cipher suite. The 3DES cipher uses a 64-bit block size, making it vulnerable to the SWEET32 birthday attack.

Impact:
An attacker who can capture a large amount of encrypted traffic (e.g., on a public Wi-Fi network) can exploit this vulnerability to recover plaintext data, potentially exposing session cookies or other sensitive information.

Remediation Steps:
1. **Identify the Service:** Determine which service is running on port 631 (commonly CUPS - Common Unix Printing System). Check its documentation for SSL/TLS configuration.
2. **Disable Weak Ciphers:** Modify the service's configuration to disable the 3DES cipher and only allow strong, modern ciphers. Use resources like the Mozilla SSL Configuration Generator to create a secure configuration.
    - **Example for a generic server (like Apache/Nginx):**
        - Disable 3DES in your cipher suite string.
        - ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:... (Do not include 3DES).
3. **Restart the Service:** Apply the changes by restarting the affected service.

3.3. Medium Findings (Summary)

These issues, while not immediately critical, contribute significantly to the overall risk posture and should be addressed in order of priority.

Service (Port)	CVSS	Vulnerability Name	Summary & Remediation
22/tcp	5.3	Weak Host Key Algorithm(s) (SSH)	**Issue:** Supports ssh-dss (DSA). **Fix:** Disable ssh-dss in /etc/ssh/sshd_config by adding or modifying HostKeyAlgorithms. Use RSA or ECDSA.
22/tcp	5.3	Weak Key Exchange (KEX) Algorithm(s) (SSH)	**Issue:** Supports weak KEX like diffie-hellman-group1-sha1. **Fix:** Disable weak KEX algorithms in /etc/ssh/sshd_config by setting KexAlgorithms to a modern set (e.g., curve25519-sha256@libssh.org,...).
22/tcp	4.3	Weak Encryption Algorithm(s) (SSH)	**Issue:** Supports CBC-mode ciphers and arcfour (RC4). **Fix:** Disable weak ciphers in /etc/ssh/sshd_config by setting Ciphers to a modern set (e.g., chacha20-poly1305@openssh.com,aes256-gcm@openssh.com,...).
631/tcp	4.3	Deprecated TLSv1.0 and TLSv1.1 Protocol	**Issue:** Supports outdated and insecure TLS protocols. **Fix:** Disable TLSv1.0 and TLSv1.1 in the service configuration (e.g., for Apache, add SSLProtocol -ALL +TLSv1.2 +TLSv1.3).
80/tcp	6.1	jQuery < 1.9.0 XSS Vulnerability (CVE-2012-6708)	**Issue:** Two instances of jQuery 1.6.2 vulnerable to XSS. **Fix:** Update jQuery to version 1.9.0 or later for the affected applications (phpMyAdmin).
80/tcp	5.0	Sensitive File Disclosure (HTTP)	**Issue:** web.config file is accessible via HTTP at /drupal/web.config. **Fix:** Restrict access to this file via web server configuration or move it outside the web root.
80/tcp	5.0	Unprotected Web App / Device Installers (HTTP)	**Issue:** phpMyAdmin setup page is publicly accessible (/phpmyadmin/setup/). **Fix:** Remove the /setup/ directory or password-protect it.
80/tcp	4.8	Cleartext Transmission of Sensitive Info	**Issue:** Login forms (Drupal, payroll_app, phpMyAdmin) submit passwords over HTTP. **Fix:** Install an SSL/TLS certificate and force HTTPS redirection for all traffic.
80/tcp	4.3	jQuery < 1.6.3 XSS Vulnerability (CVE-2011-4969)	**Issue:** Two instances of jQuery 1.6.2 vulnerable to XSS. **Fix:** Update jQuery to version 1.6.3 or later for the affected applications (phpMyAdmin).

Screenshot/Evidence:

2.1.4 Medium 22/tcp

Medium (CVSS: 5.3)

NVT: Weak Host Key Algorithm(s) (SSH)

Medium (CVSS: 5.3)

NVT: Weak Key Exchange (KEX) Algorithm(s) Supported (SSH)

Medium (CVSS: 4.3)

NVT: Weak Encryption Algorithm(s) Supported (SSH)

Medium (CVSS: 4.3)

NVT: SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection

Medium (CVSS: 6.1)

NVT: jQuery < 1.9.0 XSS Vulnerability

Medium (CVSS: 6.1)

NVT: jQuery < 1.9.0 XSS Vulnerability

Medium (CVSS: 5.0)

NVT: Sensitive File Disclosure (HTTP)

Medium (CVSS: 5.0)

NVT: Unprotected Web App / Device Installers (HTTP)

Medium (CVSS: 4.8)

NVT: Cleartext Transmission of Sensitive Information via HTTP

Medium (CVSS: 4.3)

NVT: jQuery < 1.6.3 XSS Vulnerability

3.4. Low Findings (Summary)

Service (Port)	CVSS	Vulnerability Name	Summary & Remediation
general/tcp	2.6	TCP Timestamps Information Disclosure	**Issue:** Allows calculation of system uptime. **Fix:** Disable TCP timestamps. (Linux: sysctl -w net.ipv4.tcp_timestamps=0, Windows: netsh int tcp set global timestamps=disabled)
22/tcp	2.6	Weak MAC Algorithm(s) Supported (SSH)	**Issue:** Supports weak MACs (MD5, 96-bit). **Fix:** Disable weak MACs in /etc/ssh/sshd_config by setting MACs to a modern set (e.g., hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com,...).
general/icmp	2.1	ICMP Timestamp Reply Information Disclosure	**Issue:** Host responds to ICMP timestamp requests. **Fix:** Block ICMP timestamp requests (Type 13) at the firewall

Screenshot/Evidence:

2.1.7 Low general/tcp

Low (CVSS: 2.6)

NVT: TCP Timestamps Information Disclosure

2.1.8 Low 22/tcp

Low (CVSS: 2.6)

NVT: Weak MAC Algorithm(s) Supported (SSH)

2.1.9 Low general/icmp

Low (CVSS: 2.1)

NVT: ICMP Timestamp Reply Information Disclosure

Tools Used

- Kali Linux
- Nmap (network scanning)
- OpenVAS (vulnerability scanning)
- Nikto (web server analysis)

Conclusion

The assessment revealed several vulnerabilities primarily related to **weak encryption and insecure configurations**. While no critical exploit was executed, these weaknesses could be leveraged by attackers to compromise confidentiality and integrity.
Immediate remediation is recommended for high-risk vulnerabilities, followed by gradual hardening of system configurations.

References

- NVD CVSS Calculator
- OWASP Top 10
- CIS Benchmarks
- OpenVAS Documentation
- Nmap Documentation